

Clase 201 — Fundamentos de DFIR y cadena de custodia

Parte: 9 — Forense digital y respuesta a incidentes · Fuente: NIST SP 800-86 — Guide to Integrating Forensic Techniques into Incident Response 🕒 Duración estimada: 90 min · Nivel: Fundamentos

Objetivo

Comprender qué es DFIR, en qué se diferencia la respuesta a incidentes del análisis forense, y por qué la **cadena de custodia** y la **integridad de la evidencia** son el cimiento innegociable de todo el trabajo posterior. Al terminar sabrás tratar un equipo comprometido de forma que cualquier hallazgo sea técnicamente sólido y legalmente defendible.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Distinguir** los roles de la forense digital y la respuesta a incidentes dentro de DFIR.
- 2. **Aplicar** el principio de intercambio de Locard y el orden de volatilidad a un caso real.
- 3. **Redactar** un formulario de cadena de custodia completo y verificable.
- 4. **Calcular y verificar** hashes de integridad (MD5/SHA-256) sobre evidencia adquirida.
- 5. **Identificar** los errores que contaminan evidencia y cómo evitarlos.

Temas

#	Tema	Por qué importa
1	Qué es DFIR y sus dos mitades	Marca el alcance de todo el trabajo
2	Principio de Locard	Justifica que siempre hay rastros
3	Orden de volatilidad	Define qué capturar primero
4	Cadena de custodia	Sostiene la evidencia ante un tribunal
5	Integridad por hash	Prueba que la evidencia no se alteró
6	Bloqueo de escritura	Evita contaminar el original
7	Documentación y notas contemporáneas	Reconstruye lo que hiciste y cuándo
8	Ética y autorización	Delimita qué puedes tocar legalmente

Definiciones y características

- **DFIR**: unión de *Digital Forensics* (análisis riguroso post-mortem) e *Incident Response* (contención y recuperación rápida). Característica clave: tensión entre velocidad y rigor, que hay que equilibrar en

cada caso.

- **Principio de intercambio de Locard:** todo contacto deja un rastro. En digital: cada acción de un atacante (o del propio analista) altera algún estado. Característica: nunca hay "cero huella".
- **Orden de volatilidad:** prioridad de captura según cuán rápido desaparece un dato (registros de CPU → RAM → conexiones → disco → backups). Característica: la RAM se pierde al apagar; el disco persiste.
- **Cadena de custodia:** registro documental de quién tuvo la evidencia, cuándo, dónde y qué hizo con ella. Característica: cualquier hueco la invalida.
- **Hash de integridad:** huella criptográfica (SHA-256) que prueba que un artefacto no cambió. Característica: un solo bit distinto cambia el hash entero.
- **Bloqueador de escritura (write blocker):** hardware o software que permite leer un medio sin escribir en él. Característica: garantiza que el original permanece intacto.
- **Evidencia volátil vs. persistente:** la volátil (RAM, procesos) muere al apagar; la persistente (disco) sobrevive. Característica: determina la estrategia de adquisición.

Herramientas y preparación

- **Entorno:** máquina virtual con Kali Linux o SIFT Workstation (SANS). Trabaja siempre en un **laboratorio aislado y con equipos propios o con autorización explícita por escrito**.
- **Herramientas:** `sha256sum`, `md5sum`, `hashdeep`, un editor de texto para el formulario de custodia, y una plantilla de cadena de custodia (puedes usar la de NIST o SANS).
- **Material físico simulado:** bolsas antiestáticas con etiqueta, marcador indeleble, cuaderno de notas foliado.

Laboratorio guiado

Ejercicio conceptual y práctico con archivos propios. No requiere evidencia real de terceros.

1. Crea un archivo que simule evidencia adquirida:

```
bash dd if=/dev/urandom of=evidencia.img bs=1M count=50
```

2. Calcula y guarda su hash de integridad al momento de la "adquisición":

```
bash sha256sum evidencia.img | tee evidencia.sha256
```

3. Redacta el formulario de cadena de custodia con estos campos mínimos: - Identificador único del ítem (ej. CASO-2026-001-ITEM-01). - Descripción, fabricante, número de serie. - Fecha/hora de adquisición y zona horaria (UTC recomendado). - Nombre y firma de quien adquirió. - Hash de integridad (pega el de `evidencia.sha256`). - Historial de transferencias (de → a, fecha, motivo).
4. Simula una transferencia: registra en el formulario que entregas el ítem a un "analista".
5. Verifica que la evidencia no se alteró:

```
bash sha256sum -c evidencia.sha256
```

Debe responder `evidencia.img: OK`. 6. Simula contaminación: modifica un byte y vuelve a verificar. Observa cómo `sha256sum -c` falla. Documenta el fallo en tus notas: así se ve una cadena rota.

Ejercicios

1. Enumera, en orden de volatilidad, siete fuentes de evidencia de un portátil encendido.
2. Redacta una plantilla de cadena de custodia con al menos diez campos.
3. Explica con un ejemplo por qué apagar "correctamente" un equipo puede destruir evidencia.
4. Genera hashes MD5 y SHA-256 del mismo archivo y explica por qué preferimos SHA-256.
5. Diseña un procedimiento para etiquetar y fotografiar tres dispositivos incautados.
6. Analiza un caso: un analista copió archivos con arrastrar-y-soltar desde el disco sospechoso. ¿Qué cinco cosas hizo mal?

Reto verificable

Adquiere una imagen de un pendrive propio (o de un archivo `.img` que crees), documenta su cadena de custodia completa y verifica integridad antes y después de una transferencia simulada.

Criterio de aceptación: entregas (a) el `.img`, (b) su hash SHA-256 en un archivo separado, (c) un formulario de custodia con al menos una transferencia registrada, y (d) la salida de `sha256sum -c` mostrando `OK`. Si alteras un byte, la verificación debe fallar y tú debes haberlo documentado.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
<code>sha256sum -c</code> responde <code>FAILED</code> inesperadamente	La evidencia se alteró (montaje sin write-blocker). Reinicia desde el original con bloqueo de escritura.
No recuerdas el orden de las acciones	No tomaste notas contemporáneas. Usa un cuaderno foliado o log con marca de tiempo.
El tribunal rechaza la evidencia	Hueco en la cadena de custodia. Todo cambio de manos debe estar firmado y fechado.
Hashes distintos en dos herramientas	Rutas o codificación distinta, o el archivo cambió. Verifica que apuntas al mismo objeto.
Zona horaria confusa en el informe	Usaste hora local sin indicar offset. Registra siempre en UTC.

Preguntas frecuentes

 **¿Forense e incidente son lo mismo?** No. La respuesta a incidentes prioriza contener y recuperar rápido; la forense prioriza el rigor y la reconstrucción defendible. DFIR las integra.

 **¿MD5 sirve todavía?** Para deduplicación y verificación rápida sí, pero por colisiones conocidas prefiere SHA-256 en evidencia que pueda ir a juicio.

 **¿Puedo analizar el disco original directamente?** No. Siempre trabajas sobre una copia forense verificada; el original se preserva con bloqueo de escritura.

 **¿Qué hago si contamina evidencia sin querer?** Documentalo de inmediato y con honestidad. Ocultarlo destruye tu credibilidad; registrarlo la preserva.

Referencias

- NIST SP 800-86 — *Guide to Integrating Forensic Techniques into Incident Response*: <https://csrc.nist.gov/publications/detail/sp/800-86/final>
- Carrier, B. — *File System Forensic Analysis*, Addison-Wesley 2005.
- SWGDE — *Best Practices for Digital Evidence Collection*: <https://www.swgde.org/>
- SANS DFIR — *Chain of Custody* resources: <https://www.sans.org/>

Siguiente clase

Clase 202 - El ciclo de respuesta a incidentes (NIST y SANS)